

Securing Your AI on AWS

Least privilege and IAM · Many accounts, one sign-in · Encryption and keys · Secrets and sensitive data · The front door and the network

Least privilege and IAM

Give each person or service only what it needs — nothing more.

IAM piece	What it is
User	One person's login
Group	A set of users who share permissions
Role	Temporary permissions a service or person takes on
Policy	The rules: which actions, on which resources
MFA	A second check at sign-in, like a code on your phone



A Lambda that only reads one bucket gets a role that allows exactly that — not "full S3 access".

Many accounts, one sign-in

Most organisations use several AWS accounts — development, testing, production.

Service	What it does
IAM Identity Center	One sign-in for all accounts, with the right permissions in each
Control Tower	Sets up many accounts with safety rules already in place



A developer signs in once — full access in development, read-only in production.

Encryption and keys

Encryption scrambles data so only someone with the key can read it.

Idea	What it means
At rest / in transit	Encrypt stored files and data moving across the network
AWS KMS	Creates and manages keys — every use recorded in CloudTrail
Key policy	Decides who is allowed to use the key
Masking	Hides part of a value: •••• •••• •••• 4417
Salting	Adds random data before hashing, so identical passwords look different

Secrets and sensitive data

Service	What it does
Secrets Manager	Stores passwords and API keys safely, and can rotate them
Amazon Macie	Scans S3 to find personal data you didn't know was there

✗ **API key written in the code** → visible to anyone who sees the code

✓ **API key in Secrets Manager** → code asks for it at run time

 Before building a knowledge base on 10,000 documents, Macie finds 40 files containing customers' bank details.

The front door

Service	Protects against
Amazon Cognito	Unknown users — handles sign-up and sign-in for your app
AWS WAF	Bad traffic — blocks attacks, bots and floods of requests



A rate-based WAF rule limits each user to a set number of requests every 5 minutes.
For an AI app, that protects your **token bill** as well as your servers.

The network

A VPC is your own private section of the AWS network.

Piece	What it does
Security group	Firewall around one server — allow rules only
Network ACL	Firewall around a whole subnet — allow and deny
VPC endpoint / PrivateLink	Reach AWS services without the public internet
VPC Flow Logs	Record what traffic came and went



A Lambda in a private subnet calls Bedrock through a VPC endpoint — the prompts never touch the public internet.

Putting it together

No single service makes it secure — it's the layers.



Key takeaways

- 1 Least privilege: only what's needed, nothing more
- 2 Roles for services, MFA for people
- 3 Keep secrets out of code
- 4 Find sensitive data before the AI can search it
- 5 Keep prompts off the public internet with VPC endpoints

Security is layers — no single service does it alone